

la triada de la red...

TRÍADA DE SEGURIDAD

★ CAPA 7 OSI

Autenticación · Confidencialidad · Integridad los pilares en la **capa de aplicación**.

PILAR 01

A

AUTENTICACIÓN

Confirma que el usuario o servicio es realmente quien dice ser.

PILAR 02

C

CONFIDENCIALIDAD

Asegura que la información solo sea vista y leída para los usuarios autorizadas durante su tránsito.

PILAR 03

I

INTEGRIDAD

Detecta cualquier alteración, intencional o accidental, sufrida por los datos.

pilar 01 ✨

AUTENTICACIÓN

"¿Eres realmente quien dices ser?"

● DEFINICIÓN

Es el proceso mediante el cual una aplicación verifica la identidad de un usuario o sistema. Es la parte inicial que sirve para evitar suplantaciones y asegurar que quien solicita acceso tiene las validaciones o nivel de acceso para hacerlo.

● Factores de autenticación

- ▶ **Algo que sabes:** contraseña, PIN, frase clave.
- ▶ **Algo que tienes:** token TOTP, llave U2F/FIDO2, smartcard.
- ▶ **Algo que eres:** huella, iris, reconocimiento facial.

● Mecanismos en la capa 7

- ▶ **HTTP Basic / Digest:** esquemas históricos.
- ▶ **JWT firmado:** tokens portables y verificables.
- ▶ **OAuth 2.0 / OpenID Connect:** identidad federada.
- ▶ **mTLS:** certificados X.509 mutuos.

EJEMPLO 01



Login bancario con MFA

El cliente captura su contraseña y luego un código TOTP de seis dígitos generado por su app autenticadora. Aunque la contraseña sea robada por phishing, el atacante no puede iniciar sesión sin el segundo factor.

EJEMPLO 02



Inicio de sesión con OAuth 2.0

Plataformas como Spotify o Trello permiten "Iniciar sesión con Google". Google autentica al usuario y emite un token firmado; la aplicación nunca conoce la contraseña real.

EJEMPLO 03



Autenticación biométrica

Aplicaciones bancarias móviles emplean Face ID o huella dactilar (WebAuthn / FIDO2).

pilar 02 ✨

CONFIDENCIALIDAD

"Lo que viaja por la red, solo lo leen quienes deben hacerlo."

DEFINICIÓN

Garantiza que la información que se envía por la red, o es directamente procesada por el sistema sea accesible exclusivamente para entidades o clientes autorizados. El propósito de esta es prevenir la fuga de datos sensibles y el espionaje de los datos.

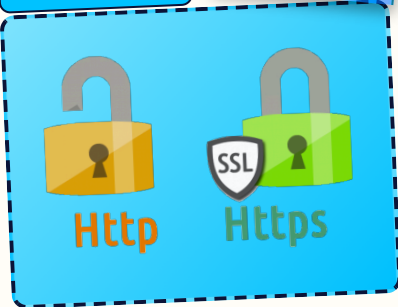
● Cifrado simétrico y asimétrico

- ▶ **AES-256-GCM:** estándar para grandes volúmenes.
- ▶ **ChaCha20-Poly1305:** alternativa móvil eficiente.
- ▶ **RSA y ECDHE:** intercambio de claves y firmas.

● Aplicaciones en la capa 7

- ▶ **HTTPS (TLS 1.3):** cifra todo el tráfico web.
- ▶ **SMTPS / IMAPS:** correo cifrado.
- ▶ **SSH:** sesiones administrativas remotas.
- ▶ **E2EE:** mensajería extremo a extremo.

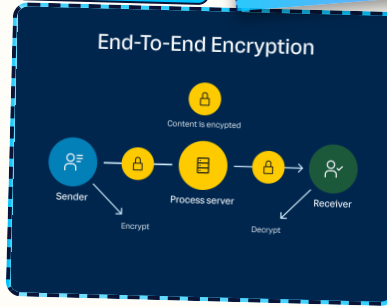
EJEMPLO 01



HTTPS en tienda en línea

Durante una compra online, los datos de la tarjeta de crédito se encriptan al viajar desde el navegador hasta la pasarela de pago, haciéndolos ilegibles para interceptores

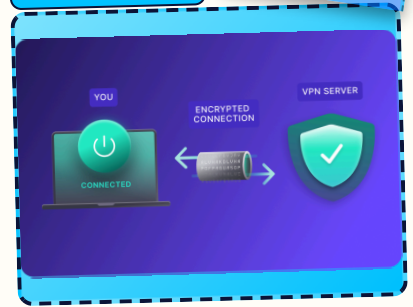
EJEMPLO 02



WhatsApp y Signal con E2EE

El protocolo Signal cifra cada mensaje con claves derivadas en el dispositivo del emisor; ni el servidor de WhatsApp puede leerlos. Solo emisor y receptor poseen las claves.

EJEMPLO 03



VPN corporativa

Un empleado remoto se conecta a la red de la empresa mediante una VPN (OpenVPN o WireGuard). Todo su tráfico se encapsula cifrado, evitando que un atacante en una red Wi-Fi pública intercepte la sesión.

pilar 03 ✨

INTEGRIDAD

"Los datos que llegan deben ser, los que se enviaron."

DEFINICIÓN

Este pilar tiene como objetivo principal la detección de cualquier modificación intencional o accidental sobre los datos ya sea cuando se envían por la red, o cuando se almacenan, este logra dar un certificado de que el mensaje recibido es el original se envió.

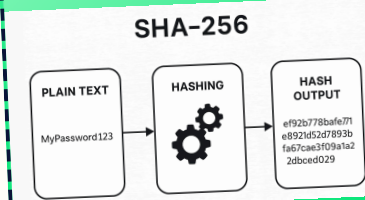
Funciones hash y firmas

- ▶ **SHA-256 / SHA-3:** huella criptográfica fija.
- ▶ **HMAC:** hash con clave secreta.
- ▶ **Ed25519 / RSA-PSS:** firmas digitales.

Aplicaciones en la capa 7

- ▶ **Etiquetas AEAD en TLS 1.3:** integridad por registro.
- ▶ **JWT firmado:** previene manipulación de claims.
- ▶ **Firmas de paquetes:** APK, RPM, DEB, MSI.

EJEMPLO 01



Verificación SHA-256 de ISO

Un servidor proporciona un archivo de actualización de software junto con su valor Hash (SHA-256). La aplicación cliente calcula el Hash al descargar; si coinciden, el archivo está íntegro y sin inyección de malware.

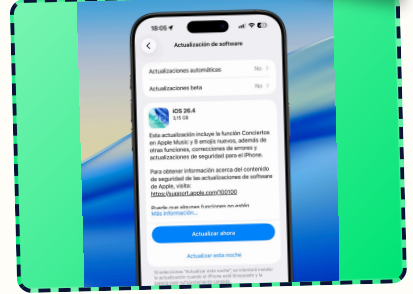
EJEMPLO 02



Firma digital de PDF / SAT

El SAT y notarios firman documentos PDF con certificados X.509. El lector verifica la firma con la clave pública del emisor y detecta cualquier modificación posterior, incluso de un solo carácter.

EJEMPLO 03



Actualizaciones firmadas del SO

Windows Update, APT y Play Store rechazan paquetes cuyo hash y firma no coincidan con la del proveedor oficial, evitando la instalación de actualizaciones maliciosas en cadena.

Bibliografías

- 1 OWASP Foundation. (2024). *Authentication Cheat Sheet*. OWASP Cheat Sheet Series. Disponible en: https://cheatsheeterseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- 2 Cloudflare, Inc. (2024). *What is application security? | Application security explained*. Cloudflare Learning Center. Disponible en: <https://www.cloudflare.com/learning/security/what-is-application-security/>
- 3 Internet Engineering Task Force (IETF). (2018). *RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3*. Disponible en: <https://datatracker.ietf.org/doc/html/rfc8446>
- 4 National Institute of Standards and Technology. (2022). *NIST SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management*. Disponible en: <https://pages.nist.gov/800-63-3/sp800-63b.html>
- 5 Mozilla Foundation. (2024). *Web Security — Mozilla Infosec Guidelines*. Disponible en: https://infosec.mozilla.org/guidelines/web_security